UNIVERSIDAD POLITÉCNICA DE

SAN LUIS POTOSÍ

CARRERA: Ingeniería en Tecnologías de la Información

MATERIA: CNO IV Seguridad Informática

TRABAJO: Propuesta de gobernanza y seguridad de la información ISO27

Ojeda Camacho José Carlos / 181629

PROFESOR: Mtro. Servando López Contreras

Contenido

Alcance 4

Información de la Organización (INTERAFAS) 4

Presentación del Proyecto a la Alta Dirección (Alcance Acotado) 5

Referencias Normativas, Legales y Regulatorias 6

Normas de Interés (Familia ISO/IEC 27000 y Estándares Relacionados) 6

Marcos Legales y Regulatorios Aplicables 7

Términos y Condiciones 8

Contexto de la Organización (Inventario de Activos de Información) 9

4.1 Activos de Información Internos 9

4.2 Activos de Información Externos 11

Liderazgo (Políticas de Seguridad de la Información) 12

5.1 Política General de Seguridad de la Información de INTERAFAS 12

5.2 Políticas Funcionales por Activo de Información 12

ACTIVO INTERNO 01: Base de Datos de Facturación y Padrón de Usuarios Corporativo 13

ACTIVO INTERNO 02: Plataforma de Control SCADA y Telemetría Operacional 13

ACTIVO INTERNO 03: Firmware y Manifiestos de Actualización de Controladores (RTU/PLC) 14

ACTIVO INTERNO 04: Registros de Auditoría y Logs del Gateway Operacional 14

ACTIVO INTERNO 05: Matriz de Riesgos y Documentación de Vulnerabilidades del Sistema 15

ACTIVO INTERNO 06: Esquemas Topológicos y Diagramas de Red Hídrica (GIS) 15

ACTIVO INTERNO 07: Credenciales y Llaves Cifradas de la Mesa de Soporte OT 15

ACTIVO INTERNO 08: Políticas Internas y Procedimientos del SGSI (ISO 27001) 16

ACTIVO INTERNO 09: Códigos Fuente de los Módulos de Gestión y Pasarela de Pagos Interna 16

ACTIVO INTERNO 10: Respaldos Periódicos de Servidores (Backups y Snapshots) 17

ACTIVO EXTERNO 11: Portal Web de Atención Ciudadana Digital 17

ACTIVO EXTERNO 12: Pasarela de Pagos Electrónicos Externa 18

ACTIVO EXTERNO 13: Base de Datos de Expedientes y Solicitudes Ciudadanas 18

ACTIVO EXTERNO 14: Canales de Redes Sociales y Difusión Institucional 19

ACTIVO EXTERNO 15: Observatorio Hídrico Metropolitano (Módulo Público) 19

ACTIVO EXTERNO 16: Bases de Datos de Proveedores y Contratistas Externos 20

ACTIVO EXTERNO 17: Certificados Digitales SSL/TLS e Infraestructura de Clave Pública (PKI) 20
ACTIVO EXTERNO 18: Plataformas de Correo Electrónico Institucional en la Nube 21
ACTIVO EXTERNO 19: Líneas de Atención Telefónica y Reportes Ciudadanos (Call Center) 21
ACTIVO EXTERNO 20: Leyes, Marcos Regulatorios y Normas Oficiales Externas (CONAGUA / DOF) 22
Planificación 22
6.1 Metodología de Evaluación de Riesgos 22
6.2 Matriz de Riesgos para las 20 Políticas Funcionales 23
Soporte (Gestión Documental y Difusión del SGSI) 30
7.1 Minuta de Reunión: Presentación del SGSI e Identificación de Acuerdos y Áreas de Oportunidad 30
Desarrollo de la Sesión 30
Acuerdos Establecidos 30
Áreas de Oportunidad Identificadas 31
7.2 Soporte Documental en Materia de Prevención y Concientización 31
Operación (Matriz RACI) 32
Evaluacion del Desempeño (Listas de Verificación del SGSI) 34
9.1 Lista de Verificación 01: Componente Web y Transaccional (IT / Pasarela de Pagos) ... 34
9.2 Lista de Verificación 02: Componente de Infraestructura Crítica y Telemetría (OT / SCADA) 35
9.3 Lista de Verificación 03: Componente de Gobernanza, Procesos y Factor Humano 36
Mejora 38
10.1 Hallazgo de Auditoría: Política Funcional que No Logró el Objetivo 38
10.2 Mejora de la Política Funcional (PF-07 Rediseñada) 38
10.3 Rediseño del Soporte de Prevención (Flyer Actualizado) 39
Conclusión 40

Alcance

Información de la Organización (INTERAFAS)

Historia y Trayectoria Institucional

INTERAFAS es el resultado de casi cinco décadas de expansión urbana y coordinación intermunicipal. Su trayectoria inició en 1978 con la formalización del primer sistema coordinado de abastecimiento de pozos en la zona urbana central. En 1984 se integró la primera planta de tratamiento regional, seguida por la interconexión de redes municipales en 1992 y la automatización del bombeo principal en 1998. La consolidación operativa llegó entre 2004 y 2008 con la creación del Centro de Operación Hidráulica y el nacimiento formal del organismo intermunicipal.

En la etapa moderna (2017 - actualidad), la organización apostó por la digitalización: en 2021 se implementó la atención ciudadana digital (trámites, reportes y recibos), y en 2023 arrancó el programa de telemetría para monitoreo remoto de presión, niveles y estado de equipos, encaminándose hacia la consolidación de un Observatorio Hídrico Metropolitano proyectado para 2026.

Misión

Gestionar agua con visión metropolitana. Prestar servicios esenciales mediante infraestructura, conocimiento técnico, atención ciudadana y coordinación entre municipios.

Visión

Una red resiliente y medible. Integrar operación, mantenimiento, información y transparencia para sostener servicios confiables frente a cambios y contingencias.

Objetivos Estratégicos

1. **Continuidad:** Garantizar un servicio esencial ininterrumpido.
2. **Resiliencia:** Mantener preparación y recuperación ante incidentes operacionales o de seguridad.
3. **Transparencia:** Asegurar el acceso y protección de la información pública.
4. **Eficiencia:** Impulsar la medición y mejora continua de la red hidráulica.
5. **Servicio:** Brindar atención ciudadana digital segura y eficiente.

Estructura Organizacional e Integrantes (Organigrama Oficial)

- **Dirección General**
    - Mtra. Valeria Serrano Cruz (Encargada de Despacho - Dirección General)
- **Áreas Estratégicas y Operativas (Encargados de Despacho):**
    - **Operación Hidráulica:** Ing. Tomás Rivas Calderón
    - **Saneamiento:** Mtra. Renata Vidal Moreau
    - **Tecnologías e Innovación:** Ing. Bruno Ferrer Lozano
    - **Jurídica:** Lic. Camila Ortega Neri
    - **Administración:** C.P. Héctor Salvatierra Ruiz
    - **Atención Ciudadana:** Mtra. Natalia Correa Vidal
    - **Monitoreo Operacional:** Ing. Emilio Navarro Costa

Presentación del Proyecto a la Alta Dirección (Alcance Acotado)

A la atención de: Mtra. Valeria Serrano Cruz (Encargada de Despacho - Dirección General) y miembros de la Alta Dirección de INTERAFAS.

Asunto: Presentación y formalización del proyecto de implementación del Sistema de Gestión de Seguridad de la Información (SGSI) bajo la norma ISO/IEC 27001.

Estimada Dirección General,

En alineación con nuestra visión institucional de consolidar una *"red resiliente y medible"* y garantizar la continuidad de nuestros servicios esenciales, se presenta formalmente el proyecto estratégico para la implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) basado en la norma internacional **ISO/IEC 27001**.

Derivado de la creciente digitalización de los servicios (atención ciudadana, portal de pagos y programas de telemetría remota), la institución se encuentra expuesta a vectores de riesgo cibernético que podrían comprometer la confidencialidad de los datos ciudadanos y la disponibilidad de la infraestructura industrial. Por ello, para garantizar un despliegue eficiente y enfocado en los puntos de mayor criticidad detectados en las evaluaciones de seguridad, el proyecto se ejecutará delimitando estrictamente su alcance a los siguientes componentes:

- **Direcciones Responsables:**
    - **Dirección de Tecnologías e Innovación** (Ing. Bruno Ferrer Lozano).
    - **Dirección de Operación Hidráulica** / **Monitoreo Operacional** (Ing. Tomás Rivas Calderón e Ing. Emilio Navarro Costa).
    - **Dirección de Atención Ciudadana** (Mtra. Natalia Correa Vidal).

- **Áreas de Ejecución:**
    - El **Centro de Datos Corporativo** (gestión de aplicativos web y pasarela de pagos).
    - El **Centro de Operación Hidráulica** (gestión de telemetría y pasarelas SCADA).
- **Procesos Críticos en los que se ejecutará el SGSI:**
    1. *Proceso de Gestión de Trámites y Pasarela de Pagos Ciudadanos:* Abarcando la validación de montos, la protección de expedientes y la prevención de manipulación de parámetros en el portal web.
    2. *Proceso de Telemetría y Control de Actuadores (ICS/SCADA):* Abarcando el monitoreo seguro del flujo de agua y la autenticación estricta en el envío de comandos hacia las válvulas de distribución (como la estación principal *V-SL-201*), asegurando la separación lógica de redes frente a la infraestructura corporativa.

La implementación de este SGSI en los procesos señalados permitirá mitigar los riesgos de vulnerabilidades críticas, cumplir con la normatividad de protección de datos y salvaguardar la estabilidad operativa de la zona metropolitana.

Referencias Normativas, Legales y Regulatorias

Normas de Interés (Familia ISO/IEC 27000 y Estándares Relacionados)

Para la correcta implementación, operación y mejora continua del Sistema de Gestión de Seguridad de la Información (SGSI) en INTERAFAS, se adoptan como referentes normativos obligatorios los siguientes estándares internacionales:

- **ISO/IEC 27001:2022 (Information security, cybersecurity and privacy protection — Information security management systems — Requirements):** Norma internacional fundamental que establece los requisitos para establecer, implementar, mantener y mejorar continuamente un SGSI, adaptado al contexto tecnológico y operativo de la organización.
- **ISO/IEC 27002:2022 (Information security, cybersecurity and privacy protection — Information security controls):** Guía de referencia que contiene las mejores prácticas y controles de seguridad de la información recomendados para mitigar los riesgos identificados en los procesos de IT y OT.
- **ISO/IEC 27005:2022 (Information security, cybersecurity and privacy protection — Guidance on managing information security risks):** Metodología de referencia para la gestión de riesgos de seguridad de la información, aplicada específicamente a la evaluación de vulnerabilidades en las plataformas web y pasarelas de telemetría.

- **ISO/IEC 27032:2012 (Information technology — Security techniques — Guidelines for cybersecurity):** Estándar complementario enfocado en la ciberseguridad, clave para abordar la interconexión y la protección de las redes corporativas frente a amenazas en el entorno digital.
- **IEC 62443 (Industrial communication networks — Network and system security for control systems):** Estándar internacional esencial para la seguridad en automatización industrial y sistemas de control (*ICS/SCADA*), aplicado directamente en la protección de la infraestructura crítica de la red hidráulica y de los centros de operación de INTERAFAS.

Marcos Legales y Regulatorios Aplicables

Dado que INTERAFAS opera como un organismo público descentralizado encargado de un servicio básico y de interés estratégico para la zona metropolitana, su gestión se encuentra sujeta al cumplimiento de los siguientes marcos legales y normativos nacionales:

- **Constitución Política de los Estados Unidos Mexicanos (Artículos 6° y 16°):** Garantiza el derecho de acceso a la información pública, la transparencia gubernamental y el derecho de toda persona a la protección de sus datos personales.
- **Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados:** Regula el tratamiento legítimo, controlado e informado de los datos personales de los ciudadanos recopilados a través de los portales de trámites y pagos digitales de la institución.
- **Ley de Transparencia y Acceso a la Información Pública del Estado de San Luis Potosí:** Establece las obligaciones de los organismos operadores de servicios públicos para mantener disponibles y seguras las plataformas de consulta pública y transparencia.
- **Ley de Aguas para el Estado de San Luis Potosí y Leyes Orgánicas Municipales:** Marco regulatorio que rige las atribuciones, facultades operativas, continuidad del servicio y responsabilidades en la administración de los recursos hídricos y la infraestructura hidráulica metropolitana.
- **Normas Oficiales Mexicanas (NOM) en materia de Agua y Saneamiento:** Regulan los parámetros de calidad del agua potable y el manejo de descargas residuales, los cuales dependen directamente de la integridad de los datos procesados en los sistemas de telemetría e infraestructura automatizada.

Términos y Condiciones

Para efectos de la comprensión integral, la correcta alineación estratégica y la toma de decisiones informadas por parte de la Alta Dirección del Organismo Intermunicipal de Agua Potable, Alcantarillado y Saneamiento (INTERAFAS) en el marco de la implementación del Sistema de Gestión de Seguridad de la Información (SGSI), resulta fundamental establecer un lenguaje común, formal y estandarizado. Con el propósito de contextualizar adecuadamente la presentación técnica y administrativa de este proyecto, se detallan y conceptualizan a continuación los términos fundamentales estipulados por la familia de normas internacionales ISO/IEC 27001, adaptando rigurosamente cada definición a la realidad operativa, tecnológica e industrial de nuestra institución:**1. Información:**

  - *Definición:* Activo que posee valor para la organización y que, por lo tanto, requiere ser protegido adecuadamente (puede encontrarse en formato digital, impreso, almacenado en medios ópticos o transmitido de forma verbal).
  - *Contexto en INTERAFAS:* Comprende desde los expedientes y datos personales de los ciudadanos en el portal web hasta las variables de telemetría y registros de operación de las plantas hidráulicas.

- **2. Seguridad de la Información:**
  - *Definición:* Preservación de la confidencialidad, la integridad y la disponibilidad de la información; adicionalmente, pueden estar implicadas otras propiedades como la autenticidad, la no repudio y la confiabilidad.
  - *Contexto en INTERAFAS:* Garantizar que los datos de pago y trámites no sean robados (confidencialidad), que los comandos hacia las válvulas y registros no sean alterados (integridad) y que los servicios ciudadanos y de agua estén operando sin interrupciones (disponibilidad).
- **3. Activo de Información:**
  - *Definición:* Todo aquello que tiene valor para la organización y que debe ser protegido, incluyendo bases de datos, manuales de procesos, software, hardware y recursos humanos.
  - *Contexto en INTERAFAS:* Las bases de datos de usuarios, los scripts de la pasarela de pagos, los controladores lógicos programables (PLCs) y la infraestructura del Centro de Operación Hidráulica.
- **4. Sistema de Gestión de Seguridad de la Información (SGSI):**
  - *Definición:* Parte de un sistema de gestión global, basado en la evaluación de riesgos del negocio, para establecer, implementar, operar, monitorear, revisar, mantener y mejorar la seguridad de la información.

    - *Contexto en INTERAFAS:* El conjunto de políticas, procedimientos, controles técnicos (en IT y OT) y directrices administrativas diseñadas para blindar la infraestructura frente a los riesgos detectados en auditorías.

- **5. Riesgo de Seguridad de la Información:**
    - *Definición:* Combinación de la probabilidad de que una amenaza se materialice aprovechando una vulnerabilidad y el impacto negativo que esto tendría sobre los activos de la organización.
    - *Contexto en INTERAFAS:* La probabilidad de que un atacante externo explote una falla de tipo *IP Spoofing* o *IDOR* para interrumpir el suministro de agua o exfiltrar datos ciudadanos.
- **6. Parte Interesada:**
    - *Definición:* Persona u organización que puede afectar, verse afectada, o percibirse como afectada por una decisión o actividad dentro del sistema de gestión.
    - *Contexto en INTERAFAS:* Los ciudadanos de la zona metropolitana, los organismos reguladores del agua, los proveedores externos, los operadores de la planta y la Dirección General.

Contexto de la Organización (Inventario de Activos de Información)

Para establecer el alcance, la valoración de riesgos y las directrices de seguridad de la información dentro del SGSI de INTERAFAS, es indispensable identificar y catalogar los elementos clave sobre los cuales opera la institución. A continuación, se definen los **20 activos de información** críticos, divididos equitativamente en 10 activos de carácter interno (procesos corporativos, bases de datos y sistemas de control) y 10 activos de carácter externo (plataformas públicas, interacciones ciudadanas y servicios en la nube).

4.1 Activos de Información Internos

1. **Base de Datos de Facturación y Padrón de Usuarios Corporativo**
    - *Descripción y Ubicación:* Repositorio central SQL alojado en el Centro de Datos Corporativo que almacena el padrón histórico, consumos y estados de cuenta de los usuarios.
    - *Clasificación de Seguridad:* Confidencial / Crítico.
2. **Plataforma de Control SCADA y Telemetría Operacional**
    - *Descripción y Ubicación:* Sistema HMI y pasarela de adquisición de datos en tiempo real ubicada en el Centro de Operación Hidráulica.

- *Clasificación/Uso:* Restringido / Crítico para la continuidad industrial.

3. **Firmware y Manifiestos de Actualización de Controladores (RTU/PLC)**
    - *Descripción y Ubicación:* Repositorios de código binario y archivos de configuración de firmware para los nodos de campo (RTU-GW-07).
    - *Clasificación/Uso:* Confidencial / Alto impacto en integridad física.
4. **Registros de Auditoría y Logs del Gateway Operacional**
    - *Descripción y Ubicación:* Archivos de bitácora y registros de conexión perimetral entre la red IT y los sistemas de control de campo.
    - *Clasificación/Uso:* Interno / Trazabilidad de seguridad.
5. **Matriz de Riesgos y Documentación de Vulnerabilidades del Sistema**
    - *Descripción y Ubicación:* Documentación técnica y reportes de auditoría de seguridad almacenados en los servidores de gestión interna.
    - *Clasificación/Uso:* Confidencial / Uso exclusivo de la Dirección de Tecnologías e Innovación.
6. **Esquemas Topológicos y Diagramas de Red Hídrica (GIS)**
    - *Descripción y Ubicación:* Mapas cartográficos y planos vectoriales de la red de distribución, válvulas (V-SL-201) y estaciones de bombeo.
    - *Clasificación/Uso:* Restringido / Infraestructura crítica.
7. **Credenciales y Llaves Cifradas de la Mesa de Soporte OT**
    - *Descripción y Ubicación:* Archivos de configuración de autenticación y hashes de acceso para perfiles de mantenimiento técnico.
    - *Clasificación/Uso:* Estrictamente Confidencial / Alto riesgo de acceso.
8. **Políticas Internas y Procedimientos del SGSI (ISO 27001)**
    - *Descripción y Ubicación:* Repositorio documental normativo que rige los lineamientos de seguridad para el personal administrativo y operativo.
    - *Clasificación/Uso:* Interno / Gobernanza institucional.
9. **Códigos Fuente de los Módulos de Gestión y Pasarela de Pagos Interna**
    - *Descripción y Ubicación:* Archivos en PHP, JavaScript y scripts de automatización ubicados en los servidores web de desarrollo y producción.
    - *Clasificación/Uso:* Confidencial / Propiedad intelectual y transaccional.
10. **Respaldos Periódicos de Servidores (Backups y Snapshots)**

- *Descripción y Ubicación:* Copias de seguridad cifradas de las bases de datos ciudadanas y de operación almacenadas en almacenamiento secundario.
- *Clasificación/Uso:* Confidencial / Recuperación ante desastres.

4.2 Activos de Información Externos

1. **Portal Web de Atención Ciudadana Digital**
    - *Descripción y Ubicación:* Interfaz pública en internet que permite a los ciudadanos realizar trámites, reportes y consultas de saldo.
    - *Clasificación/Uso:* Público / Interacción ciudadana masiva.
2. **Pasarela de Pagos Electrónicos Externa**
    - *Descripción y Ubicación:* API y pasarela conectada con instituciones bancarias terceras para procesar el pago de recibos de agua.
    - *Clasificación/Uso:* Confidencial / Transaccional regulado (PCI-DSS).
3. **Base de Datos de Expedientes y Solicitudes Ciudadanas**
    - *Descripción y Ubicación:* Registros de peticiones, folios de reportes de fugas e historiales de servicio vinculados a los usuarios externos.
    - *Clasificación/Uso:* Reservado / Protección de Datos Personales.
4. **Canales de Redes Sociales y Difusión Institucional**
    - *Descripción y Ubicación:* Perfiles oficiales utilizados para comunicar avisos de corte, suspensión de servicios y programas hídricos.
    - *Clasificación/Uso:* Público / Comunicación oficial.
5. **Observatorio Hídrico Metropolitano (Módulo Público)**
    - *Descripción y Ubicación:* Plataforma de consulta pública que muestra indicadores operativos, comerciales y ambientales a la ciudadanía.
    - *Clasificación/Uso:* Público / Transparencia y rendición de cuentas.
6. **Bases de Datos de Proveedores y Contratistas Externos**
    - *Descripción y Ubicación:* Expedientes legales, fiscales y técnicos de empresas externas que brindan servicios de mantenimiento y obra hidráulica.
    - *Clasificación/Uso:* Confidencial / Gestión administrativa.
7. **Certificados Digitales SSL/TLS e Infraestructura de Clave Pública (PKI)**
    - *Descripción y Ubicación:* Certificados emitidos por autoridades certificadoras externas para cifrar las comunicaciones web del organismo.
    - *Clasificación/Uso:* Crítico / Seguridad en tránsito.

8. **Plataformas de Correo Electrónico Institucional en la Nube**
    - *Descripción y Ubicación:* Servicios de mensajería y colaboración corporativa utilizados para la comunicación oficial con dependencias y usuarios.
    - *Clasificación/Uso:* Interno / Comunicaciones institucionales.
9. **Líneas de Atención Telefónica y Reportes Ciudadanos (Call Center Externo/Soporte)**
    - *Descripción y Ubicación:* Registros de llamadas de usuarios reportando incidencias en la red de agua potable.
    - *Clasificación/Uso:* Confidencial / Datos de contacto ciudadano.
10. **Leyes, Marcos Regulatorios y Normas Oficiales Externas (CONAGUA / DOF)**
    - *Descripción y Ubicación:* Compendio de marcos jurídicos federales y estatales que dictan las obligaciones normativas del organismo operador.
    - *Clasificación/Uso:* Público / Cumplimiento legal.

Liderazgo (Políticas de Seguridad de la Información)

5.1 Política General de Seguridad de la Información de INTERAFAS

La Dirección General del Organismo Intermunicipal de Agua Potable, Alcantarillado y Saneamiento (**INTERAFAS**), en su compromiso ineludible por garantizar servicios hídricos eficientes, seguros y de calidad para la zona metropolitana, emite la presente **Política General de Seguridad de la Información**:

"INTERAFAS se compromete a proteger todos sus activos de información —tanto en el ámbito corporativo y de atención ciudadana (IT) como en la infraestructura de control industrial y telemetría (OT)— frente a cualquier amenaza interna o externa, deliberada o accidental. La institución garantiza la ***Confidencialidad, Integridad y Disponibilidad*** *de la información mediante la implementación, mantenimiento y mejora continua de un Sistema de Gestión de Seguridad de la Información (SGSI) basado en la norma ISO/IEC 27001. Todo el personal administrativo, operativo, contratistas y proveedores externos están obligados a cumplir rigurosamente con los lineamientos, políticas funcionales y controles establecidos para salvaguardar la continuidad del servicio y la confianza de la ciudadanía."*

5.2 Políticas Funcionales por Activo de Información

A continuación, se desarrollan las 20 políticas funcionales, cada una estructurada bajo sus componentes normativos de Estándar, Directriz, Procedimiento y Línea Base, vinculadas directamente a los activos de la institución:

ACTIVO INTERNO 01: Base de Datos de Facturación y Padrón de Usuarios Corporativo

- **Estándar:** ISO/IEC 27001 (Control A.8.11 Enmascaramiento de datos y A.8.24 Uso de criptografía).
- **Directriz:** Toda consulta, modificación o extracción de datos del padrón histórico y consumos debe realizarse bajo estricto principio de menor privilegio, prohibiendo el uso de bases de datos de producción en entornos de pruebas sin enmascaramiento previo.
- **Procedimiento:**
    1. Solicitar autorización formal ante la Dirección de Tecnologías e Innovación.
    2. Aplicar scripts de enmascaramiento de PII (Información de Identificación Personal).
    3. Registrar la sesión de acceso en las bitácoras de auditoría de la base de datos SQL.
- **Línea Base:** Uso obligatorio de cifrado AES-256 en reposo, contraseñas de administración con rotación cada 90 días y bloqueo automático de sesiones inactivas a los 15 minutos.

ACTIVO INTERNO 02: Plataforma de Control SCADA y Telemetría Operacional

- **Estándar:** IEC 62443 / ISO/IEC 27001 (Control A.8.9 Gestión de configuración y A.8.20 Seguridad en redes).
- **Directriz:** La red del Centro de Operación Hidráulica debe mantenerse rigurosamente segmentada de la red corporativa de internet, prohibiendo conexiones directas sin pasarelas de inspección (*firewalls*) y sistemas de detección de anomalías.
- **Procedimiento:**
    1. Validar la topología de red antes de conectar cualquier dispositivo de campo.
    2. Inspeccionar el tráfico HMI mediante reglas de control de flujo en el *gateway*.
    3. Reportar cualquier desconexión de telemetría al Centro de Operaciones.
- **Línea Base:** Uso exclusivo de protocolos seguros (HTTPS/MQTTS con certificados internos), prohibición de puertos de administración remota expuestos (Telnet/HTTP plano) y respaldo diario de configuraciones HMI.

ACTIVO INTERNO 03: Firmware y Manifiestos de Actualización de Controladores (RTU/PLC)

- **Estándar:** ISO/IEC 27001 (Control A.8.30 Gestión de vulnerabilidades técnicas y A.8.8 Gestión de archivos).
- **Directriz:** Ninguna actualización de firmware (RTU-GW-07) podrá ser instalada en los nodos de campo sin haber pasado por una verificación estricta de integridad criptográfica y pruebas de laboratorio.
- **Procedimiento:**
    1. Descargar el manifiesto de actualización desde el repositorio oficial validado.
    2. Calcular y contrastar la firma SHA-256 del binario.
    3. Ejecutar la instalación mediante autenticación multifactor o credenciales autorizadas de soporte.
- **Línea Base:** Prohibición absoluta de almacenar hashes de contraseñas en texto plano o SHA-1 en los manifiestos públicos; uso obligatorio de firmas digitales asimétricas para paquetes de actualización.

ACTIVO INTERNO 04: Registros de Auditoría y Logs del Gateway Operacional

- **Estándar:** ISO/IEC 27001 (Control A.8.15 Registro de eventos y A.8.16 Monitoreo de actividades).
- **Directriz:** Todos los intentos de acceso, peticiones HTTP y modificaciones de cabeceras en el *gateway* operacional deben ser registrados y respaldados en un servidor de *logs* centralizado e inmutable.
- **Procedimiento:**
    1. Configurar la retención automática de bitácoras por un período mínimo de 12 meses.
    2. Revisar semanalmente los reportes de anomalías de IP (detección de *IP Spoofing* o falsificación de X-Forwarded-For).
    3. Archivar los registros en almacenamiento secundario de solo lectura.
- **Línea Base:** Sincronización horaria obligatoria mediante NTP interno, alertas automáticas ante más de 3 intentos fallidos de autenticación perimetral.

ACTIVO INTERNO 05: Matriz de Riesgos y Documentación de Vulnerabilidades del Sistema

- **Estándar:** ISO/IEC 27005 / ISO/IEC 27001 (Control A.5.1 Políticas de seguridad de la información).
- **Directriz:** La matriz de riesgos y los reportes de auditoría de vulnerabilidades son documentos altamente confidenciales, cuyo acceso está restringido exclusivamente a la Alta Dirección y al equipo de gestión de seguridad.
- **Procedimiento:**
    1. Actualizar la matriz trimestralmente o tras cada auditoría técnica.
    2. Clasificar los hallazgos según su impacto (Crítico, Alto, Medio, Bajo).
    3. Asignar responsables y plazos de remediación formal.
- **Línea Base:** Almacenamiento en repositorio interno con cifrado en tránsito y en reposo, control de versiones documentales y marca de agua institucional de confidencialidad.

ACTIVO INTERNO 06: Esquemas Topológicos y Diagramas de Red Hídrica (GIS)

- **Estándar:** ISO/IEC 27001 (Control A.5.9 Inventario de información y otros activos asociados).
- **Directriz:** Los planos cartográficos, ubicaciones de válvulas críticas (V-SL-201) y diagramas GIS de la red hidráulica no deben ser divulgados en canales públicos ni accesibles sin credenciales institucionales.
- **Procedimiento:**
    1. Registrar cada usuario con acceso a los planos GIS en el directorio activo.
    2. Restringir la exportación masiva de datos cartográficos sensibles.
    3. Realizar auditorías de acceso semestrales sobre la plataforma GIS.
- **Línea Base:** Cifrado de archivos vectoriales, marcas de identificación de usuario en descargas de planos y control estricto de dispositivos USB autorizados.

ACTIVO INTERNO 07: Credenciales y Llaves Cifradas de la Mesa de Soporte OT

- **Estándar:** ISO/IEC 27001 (Control A.5.17 Información de autenticación y A.8.24 Uso de criptografía).
- **Directriz:** Las contraseñas, tokens y llaves de acceso del personal de soporte técnico y mantenimiento industrial deben cumplir con altos estándares de complejidad y estar protegidas mediante funciones derivadas de claves seguras.

- **Procedimiento:**
    1. Generar contraseñas robustas de al menos 14 caracteres (alfanuméricos y símbolos).
    2. Prohibir el almacenamiento de credenciales en archivos de configuración de texto plano accesibles por red.
    3. Revocar de forma inmediata las credenciales al concluir contratos o rotación de personal.
- **Línea Base:** Uso obligatorio de algoritmos robustos de *hashing* con sal (como Argon2id o bcrypt) y prohibición total del uso de SHA-1 o MD5 para autenticación.

ACTIVO INTERNO 08: Políticas Internas y Procedimientos del SGSI (ISO 27001)

- **Estándar:** ISO/IEC 27001 (Control A.5.3 Segregación de funciones y A.6.3 Concientización, educación y capacitación).
- **Directriz:** Todo el personal de INTERAFAS debe ser capacitado y evaluado anualmente en las políticas del SGSI, asegurando la comprensión de sus responsabilidades en materia de seguridad.
- **Procedimiento:**
    1. Difundir las políticas actualizadas a través del portal interno.
    2. Impartir talleres obligatorios de inducción en ciberseguridad para nuevos ingresos.
    3. Documentar las constancias de participación del personal.
- **Línea Base:** Disponibilidad de la versión vigente del manual del SGSI en la intranet institucional con control de cambios y aprobación formal de la Dirección General.

ACTIVO INTERNO 09: Códigos Fuente de los Módulos de Gestión y Pasarela de Pagos Interna

- **Estándar:** ISO/IEC 27001 (Control A.8.28 Codificación segura y A.8.32 Gestión de cambios).
- **Directriz:** Todo código fuente desarrollado internamente para los portales web y sistemas de pagos debe someterse a revisiones de seguridad y pruebas de análisis estático antes de ser promovido al entorno de producción.
- **Procedimiento:**
    1. Desarrollar bajo los lineamientos de codificación segura (OWASP Top 10).
    2. Realizar pruebas de validación de parámetros para prevenir inyecciones SQL y manipulaciones (*Parameter Tampering*).

3. Autorizar despliegues mediante doble firma técnica (desarrollador y responsable de TI).

- **Línea Base:** Control de versiones mediante Git privado, separación estricta entre entornos de desarrollo, pruebas y producción.

ACTIVO INTERNO 10: Respaldos Periódicos de Servidores (Backups y Snapshots)

- **Estándar:** ISO/IEC 27001 (Control A.8.13 Copias de seguridad de la información).
- **Directriz:** Se deben realizar respaldos automáticos, cifrados e íntegros de toda la información crítica corporativa y operativa, asegurando la capacidad de recuperación ante desastres (*Disaster Recovery*).
- **Procedimiento:**
    1. Ejecutar respaldos incrementales diarios y respaldos completos semanales.
    2. Almacenar al menos una copia de seguridad en un sitio físico o nube independiente (regla 3-2-1).
    3. Realizar pruebas de restauración semestrales para verificar la integridad de los datos.
- **Línea Base:** Cifrado AES-256 en medios de respaldo, bitácora de ejecución de *backups* y validación automática de sumas de verificación (*checksums*).

ACTIVO EXTERNO 11: Portal Web de Atención Ciudadana Digital

- **Estándar:** ISO/IEC 27001 (Control A.8.20 Seguridad en redes y A.8.26 Aplicaciones en redes públicas).
- **Directriz:** El portal público de trámites y reportes ciudadanos debe contar con mecanismos robustos de defensa perimetral, validación estricta de entradas y protección contra ataques web automatizados.
- **Procedimiento:**
    1. Implementar un WAF (*Web Application Firewall*) para filtrar peticiones maliciosas.
    2. Monitorear constantemente la disponibilidad y tiempos de respuesta del portal.
    3. Corregir de forma inmediata cualquier vulnerabilidad reportada en auditorías externas.
- **Línea Base:** Uso obligatorio de HTTPS con HSTS habilitado, cifrado TLS 1.3 y certificados digitales vigentes emitidos por autoridades confiables.

ACTIVO EXTERNO 12: Pasarela de Pagos Electrónicos Externa

- **Estándar:** ISO/IEC 27001 / PCI-DSS (Control A.8.24 Uso de criptografía y A.8.20).
- **Directriz:** Las transacciones financieras y cobros de recibos procesados mediante pasarelas externas deben garantizar el aislamiento de datos bancarios, prohibiendo el almacenamiento de información sensible de tarjetas (*CVV/PAN*) en servidores propios de INTERAFAS.
- **Procedimiento:**
    1. Integrar pasarelas de pago mediante *tokens* cifrados o redirección segura (Iframe/API de pasarelas certificadas).
    2. Validar que la API de pagos compruebe la integridad de los montos para evitar manipulación de parámetros de negocio (*Parameter Tampering*).
    3. Revisar los reportes de conciliación bancaria diariamente.
- **Línea Base:** Cumplimiento con estándares PCI-DSS, pasarelas con cifrado extremo a extremo y bitácoras de transacciones aprobadas/rechazadas.

ACTIVO EXTERNO 13: Base de Datos de Expedientes y Solicitudes Ciudadanas

- **Estándar:** ISO/IEC 27001 / Ley de Protección de Datos (Control A.5.33 Protección de registros y PII).
- **Directriz:** Los expedientes, folios de reportes y datos personales de los ciudadanos almacenados en la plataforma externa deben ser tratados conforme a la normatividad de privacidad, evitando exposiciones por IDOR (Referencias Directas a Objetos Inseguros).
- **Procedimiento:**
    1. Aplicar controles estrictos de autorización basada en roles (RBAC) en las consultas de expedientes.
    2. Validar que cada petición de expediente ciudadano verifique la sesión y propiedad del solicitante.
    3. Eliminar o anonimizar datos personales una vez cumplido el plazo legal de conservación.
- **Línea Base:** Control de acceso por tokens de sesión únicos, prohibición de numeración secuencial predecible en identificadores de expedientes.

ACTIVO EXTERNO 14: Canales de Redes Sociales y Difusión Institucional

- **Estándar:** ISO/IEC 27001 (Control A.5.14 Uso de información de contacto y A.5.19 Seguridad en la relación con proveedores).
- **Directriz:** Las cuentas oficiales en redes sociales empleadas para comunicar avisos de suspensión y programas hídricos deben contar con medidas reforzadas de autenticación para prevenir suplantaciones o ataques de ingeniería social.
- **Procedimiento:**
    1. Configurar Autenticación Multifactor (MFA) en todas las cuentas institucionales de difusión.
    2. Limitar el acceso administrativo a un número reducido de personas autorizadas en Comunicación Social.
    3. Monitorear canales oficiales para detectar perfiles falsos o usurpación de identidad.
- **Línea Base:** Uso de llaves de seguridad físicas o aplicaciones autenticadoras normadas, prohibición de contraseñas compartidas.

ACTIVO EXTERNO 15: Observatorio Hídrico Metropolitano (Módulo Público)

- **Estándar:** ISO/IEC 27001 (Control A.8.14 Divulgación de información y A.8.26).
- **Directriz:** La plataforma pública de consulta de indicadores operativos y ambientales debe filtrar estrictamente la información para mostrar únicamente datos agregados y autorizados, protegiendo la topología interna subyacente.
- **Procedimiento:**
    1. Revisar los conjuntos de datos publicados en el portal del Observatorio.
    2. Aislar la base de datos pública del servidor de telemetría maestro mediante una arquitectura de tres capas (*DMZ*).
    3. Realizar pruebas de inyección y saneamiento de salidas (*Output Encoding*).
- **Línea Base:** Servidor web público sin privilegios de escritura sobre bases de datos operacionales, políticas de CORS (*Cross-Origin Resource Sharing*) restrictivas.

ACTIVO EXTERNO 16: Bases de Datos de Proveedores y Contratistas Externos

- **Estándar:** ISO/IEC 27001 (Control A.5.19 Seguridad en la relación con proveedores y A.5.21 Gestión de la seguridad en la cadena de suministro).
- **Directriz:** Todo proveedor externo que preste servicios tecnológicos o de mantenimiento industrial debe firmar acuerdos de confidencialidad (NDA) y cumplir con los requisitos de seguridad establecidos por INTERAFAS.
- **Procedimiento:**
    1. Evaluar el perfil de riesgo del proveedor antes de otorgar credenciales de acceso.
    2. Limitar el acceso de terceros exclusivamente al tiempo y los recursos estrictamente necesarios para su labor.
    3. Supervisar las actividades técnicas realizadas por contratistas en las instalaciones.
- **LíneaBase:** Contratos con cláusulas obligatorias de ciberseguridad, bitácoras de ingreso de personal externo y revocación inmediata de accesos al finalizar el servicio.

ACTIVO EXTERNO 17: Certificados Digitales SSL/TLS e Infraestructura de Clave Pública (PKI)

- **Estándar:** ISO/IEC 27001 (Control A.8.24 Uso de criptografía).
- **Directriz:** Todos los servicios web, pasarelas de pago y portales de atención ciudadana deben operar bajo certificados digitales válidos y vigentes, asegurando la cifrado robusto de las comunicaciones en tránsito.
- **Procedimiento:**
    1. Monitorear las fechas de expiración de los certificados SSL/TLS con 30 días de anticipación.
    2. Renovar certificados utilizando autoridades certificadoras reconocidas.
    3. Deshabilitar conjuntos de cifrados obsoletos (como TLS 1.0 y TLS 1.1).
- **Línea Base:** Uso exclusivo de TLS 1.2 y TLS 1.3 con suites de cifrado seguro y políticas de renovación automatizada mediante ACME/Let's Encrypt o autoridades internas.

ACTIVO EXTERNO 18: Plataformas de Correo Electrónico Institucional en la Nube

- **Estándar:** ISO/IEC 27001 (Control A.5.7 Inteligencia de amenazas y A.8.7 Protección contra malware).
- **Directriz:** El servicio de correo electrónico institucional debe contar con filtros avanzados contra *phishing*, *spam* y suplantación de dominios para proteger al personal frente a campañas de ingeniería social.
- **Procedimiento:**
    1. Configurar registros de validación de dominios (SPF, DKIM y DMARC en modo estricto).
    2. Habilitar escaneo automático de archivos adjuntos y enlaces maliciosos en la nube.
    3. Capacitar al personal para identificar correos electrónicos sospechosos.
- **Línea Base:** Autenticación Multifactor obligatoria para todas las cuentas de correo, bloqueo de extensiones ejecutables en archivos adjuntos.

ACTIVO EXTERNO 19: Líneas de Atención Telefónica y Reportes Ciudadanos (Call Center)

- **Estándar:** ISO/IEC 27001 (Control A.5.10 Uso aceptable de la información y A.6.7 Teletrabajo/Atención remota).
- **Directriz:** El personal del centro de atención telefónica debe seguir protocolos estrictos de verificación de identidad antes de registrar o modificar folios de reportes ciudadanos sensibles.
- **Procedimiento:**
    1. Solicitar datos de validación al ciudadano (número de cuenta o folio anterior).
    2. Registrar las llamadas en la plataforma CRM segura sin anotar información bancaria o contraseñas.
    3. Resguardar las grabaciones de llamadas conforme a los tiempos legales establecidos.
- **Línea Base:** Estaciones de trabajo de atención telefónica con bloqueo de puertos USB, sistemas CRM con restricciones de visualización de datos personales.

ACTIVO EXTERNO 20: Leyes, Marcos Regulatorios y Normas Oficiales Externas (CONAGUA / DOF)

- **Estándar:** ISO/IEC 27001 (Control A.5.36 Cumplimiento de requisitos legales y normativos).
- **Directriz:** INTERAFAS debe mantener un registro actualizado y un proceso de revisión continua de las leyes federales, estatales y normativas oficiales que rigen el sector hídrico y la seguridad de la información.
- **Procedimiento:**
    1. Revisar trimestralmente las publicaciones del Diario Oficial de la Federación (DOF) y gacetas estatales.
    2. Alinear las políticas internas del SGSI con los requerimientos de la CONAGUA y leyes de transparencia.
    3. Documentar el estatus de cumplimiento normativo ante auditorías externas.
- **Línea Base:** Repositorio normativo institucional actualizado, asignación de un responsable de cumplimiento legal y regulatorio dentro de la estructura organizacional.

Planificación

Para dar cumplimiento al requisito **PR02-16**, se establece la metodología de evaluación y tratamiento de riesgos basada en la norma **ISO/IEC 27005**, integrando la matriz de riesgos para las amenazas asociadas a las 20 políticas funcionales y la estrategia institucional para administrar dichos riesgos.

6.1 Metodología de Evaluación de Riesgos

El nivel de riesgo inherente se calcula mediante la fórmula $R = P \times I$ (Probabilidad por Impacto), utilizando una escala cuantitativa del **1 al 5**:

- **Probabilidad (P): 1** (Muy Baja / Rara), **2** (Baja / Improbable), **3** (Media / Posible), **4** (Alta / Probable), **5** (Muy Alta / Casi Segura).
- **Impacto (I): 1** (Insignificante), **2** (Menor), **3** (Moderado), **4** (Mayor), **5** (Catastrófico).
- **Nivel de Riesgo (R):**
    - **1 a 4 (Bajo):** Riesgo tolerable; se monitorea dentro de la operación normal.
    - **5 a 9 (Medio):** Requiere controles preventivos y supervisión periódica.
    - **10 a 15 (Alto):** Requiere plan de mitigación prioritario a corto plazo.
    - **16 a 25 (Crítico):** Inaceptable; exige acción correctiva inmediata y controles estrictos de seguridad

6.2 Matriz de Riesgos para las 20 Políticas Funcionales

ID	*Activo / Política Funcional*	*Amenaza Identificada*	*Vulnerabilidad Asociada*	*P*	*I*	*Riesgo (R)*	*Estrategia*	*Control / Acción de Administración*
PF-01	BD de Facturación y Padrón (Interno)	Exfiltración masiva de datos mediante Inyección SQL (Blind SQLi).	Falta de sanitización en entradas y consultas dinámicas no parametrizadas.	5	5	**25 (Crítico)**	Mitigar	Implementar consultas preparadas (*Prepared Statements*), cifrado AES-256 en reposo y enmascaramiento de PII.
PF-02	Plataforma SCADA y Telemetría (Interno)	Manipulación remota de actuadores y lectura no autorizada de variables.	Segmentación lógica deficiente entre la red corporativa (IT) y la red de control (OT).	4	5	**20 (Crítico)**	Mitigar	Aislar la red OT bajo el modelo Purdue, implementar firewalls industriales y requerir doble confirmación en actuadores (V-SL-201).
PF-03	Firmware y Manifiestos RTU/PLC (Interno)	Inyección de firmware malicioso y compromiso de nodos de campo (RTU-GW-07).	Exposición de hashes débiles (SHA-1) en manifiestos públicos y falta de firma digital.	4	5	**20 (Crítico)**	Mitigar	Eliminar hashes de archivos públicos, exigir firma criptográfica SHA-256/RSA en binarios y autenticación mutua (mTLS).

PF-04	Registros y Logs del Gateway (Interno)	Evasión de controles perimetrales mediante suplantación de IP (*IP Spoofing*).	Confianza ciega en la cabecera HTTP X-Forwarded-For sin validación de socket TCP.	5	4	**20 (Crítico)**	Mitigar	Validar el acceso a nivel de socket de red real, ignorar cabeceras inyectadas por el cliente y centralizar bitácoras en un servidor SIEM inmutable.
PF-05	Matriz de Riesgos y Doc. de Vulnerabilidades (Interno)	Fuga de información estratégica sobre debilidades técnicas de la institución.	Controles de acceso laxos en repositorios documentales y almacenamiento sin cifrar.	3	4	**12 (Alto)**	Mitigar	Restringir acceso exclusivamente a la Alta Dirección y TI, aplicar cifrado documental y marcas de agua institucionales.
PF-06	Esquemas Topológicos y Red GIS (Interno)	Reconocimiento de dependencias operacionales para planificar sabotaje físico o lógico.	API de contexto de activos (/operations/asset-context.php) sin restricción de profundidad.	4	4	**16 (Crítico)**	Mitigar	Ocultar metadatos topológicos en respuestas de API, aplicar control de acceso basado en roles (RBAC) y bloquear exportación masiva de planos.

PF-07	Credenciales de Mesa de Soporte OT (Interno)	Ataque de fuerza bruta / diccionario fuera de línea contra cuentas privilegiadas.	Uso de algoritmos de *hashing* obsoletos (SHA-1 sin *salt*) y contraseñas predecibles (Soporte343).	5	5	**25 (Crítico)**	Mitigar	Migrar a algoritmos robustos (Argon2id o bcrypt con *salt*), imponer longitud mínima de 14 caracteres y habilitar MFA.
PF-08	Políticas y Procedimientos del SGSI (Interno)	Incumplimiento normativo o errores operativos por desconocimiento del personal.	Falta de difusión, capacitación continua y actualización de los manuales de seguridad.	3	3	**9 (Medio)**	Asumir / Mitigar	Ejecutar campañas anuales de concientización obligatoria, evaluar al personal y mantener control de versiones en la intranet.
PF-09	Códigos Fuente Web y Pagos (Interno)	Descubrimiento de lógica interna, rutas ocultas y credenciales harcodeadas.	Presencia de archivos de respaldo residuales (.bak, .old) y modo *debug* activo en producción.	4	4	**16 (Crítico)**	Evitar / Mitigar	Eliminar archivos residuales del servidor de producción, deshabilitar impresión de errores en pantalla e integrar revisiones SAST en Git.
PF-10	Respaldos de Servidores / Backups (Interno)	Pérdida total de información operativa o	Copias de seguridad almacenadas en la misma red sin aislamiento ni	2	5	**10 (Alto)**	Mitigar / Transferir	Aplicar la regla de respaldo 3-2-1 con copias inmutables fuera de línea y en

		secuestro de datos (*Ransomware*).	pruebas de restauración.					nube cifrada, realizando pruebas semestrales de recuperación.
PF-11	Portal Web de Atención Ciudadana (Externo)	Secuestro de sesiones de usuarios e inyección de contenido malicioso (XSS / HTML).	Fijación de sesión (*Session Fixation*) y falta de codificación de salida en el módulo de reportes.	4	4	**16 (Crítico)**	Mitigar	Regenerar el identificador de sesión tras la autenticación, configurar cookies con banderas HttpOnly/Secure y desplegar un WAF perimetral.
PF-12	Pasarela de Pagos Electrónicos (Externo)	Fraude financiero mediante alteración del importe a pagar (*Parameter Tampering*).	Validación de montos delegada al lado del cliente sin comprobación de integridad en el servidor.	5	5	**25 (Crítico)**	Mitigar / Transferir	Calcular y validar los importes exclusivamente en el *backend* contra la base de datos de facturación y delegar el cobro a un procesador certificado PCI-DSS.
PF-13	BD de Expedientes	Acceso no autorizado a trámites, recibos e	Referencias Directas a Objetos Inseguros (IDOR / BOLA) con identificadores	5	4	**20 (Crítico)**	Mitigar	Implementar validación estricta de pertenencia del objeto en cada

	Ciudadanos (Externo)	historiales de terceros.	secuenciales sin validar propiedad.					petición HTTP y sustituir IDs secuenciales por UUIDs.
PF-14	Redes Sociales y Difusión (Externo)	Suplantación de identidad institucional y publicación de falsas alertas de corte de agua.	Cuentas administradas con contraseñas compartidas y ausencia de doble factor de autenticación.	3	3	**9 (Medio)**	Mitigar	Habilitar Autenticación Multifactor (MFA) obligatoria, limitar permisos de publicación y usar gestores de contraseñas corporativos.
PF-15	Observatorio Hídrico Metropolitano (Externo)	Abuso de consultas públicas para inferir el estado crítico de la infraestructura.	Conexión directa entre el portal de consulta pública y las bases de datos operacionales.	3	3	**9 (Medio)**	Mitigar	Aislar el portal en una zona desmilitarizada (DMZ) alimentada únicamente con datos agregados y aplicar límites de tasa (*Rate Limiting*).
PF-16	BD de Proveedores y Contratistas (Externo)	Vinculación fraudulenta de contratos y escalada de	Confianza en cookies de rol manipulables en el cliente (role=admin) y validación	4	4	**16 (Crítico)**	Mitigar	Gestionar los roles exclusivamente en la sesión del servidor, firmar acuerdos de confidencialidad (NDA) y auditar

		privilegios por terceros.	inconsistente de vínculos.					privilegios de contratistas.
PF-17	Certificados SSL/TLS y PKI (Externo)	Interceptación de tráfico en tránsito (*Man-in-the-Middle*) e indisponibilidad por caducidad.	Uso de protocolos obsoletos (TLS 1.0/1.1) o vencimiento no monitoreado de certificados digitales.	2	4	**8 (Medio)**	Mitigar	Forzar el uso exclusivo de TLS 1.2/1.3 con HSTS activo y automatizar la renovación de certificados con alertas previas de 30 días.
PF-18	Correo Electrónico Institucional (Externo)	Compromiso de cuentas de empleados mediante campañas de *Phishing* o *Malware*.	Ausencia de registros de autenticación de dominio y falta de filtrado de archivos adjuntos.	4	3	**12 (Alto)**	Mitigar	Configurar registros SPF, DKIM y DMARC en modo estricto, bloquear adjuntos ejecutables y exigir MFA en todas las cuentas de correo.
PF-19	Líneas de Atención / Call Center (Externo)	Ingeniería social telefónica para obtener datos personales o modificar reportes ciudadanos.	Falta de protocolos estandarizados de verificación de identidad del titular de la cuenta.	3	2	**6 (Medio)**	Asumir / Mitigar	Establecer un guion obligatorio de validación de identidad antes de brindar información y restringir la vista de datos sensibles en el CRM.

PF-20	Leyes y Marcos Regulatorios (Externo)	Sanciones legales, multas o clausuras por incumplimiento en protección de datos o calidad del agua.	Desactualización respecto a reformas en la Ley de Protección de Datos o normativas de CONAGUA.	2	4	**8 (Medio)**	Evitar / Mitigar	Realizar revisiones jurídicas trimestrales del marco normativo y auditar la alineación de los controles del SGSI con la legislación vigente.

Probabilidad (P) ↓ \ Impacto (I) →	01 - INSIGNIFICANTE	02 - MENOR	03 - SIGNIFICATIVO	04 - MAYOR	05 - SEVERO
05 – CASI SEGURO	05 (Medio)	10 (Alto)	15 (Muy Alto)	**20 (Extremo)PF-04, PF-13**	**25 (Extremo)PF-01, PF-07, PF-12**
04 – PROBABLE	04 (Medio)	08 (Medio)	**12 (Alto)PF-18**	**16 (Muy Alto)PF-06, PF-09, PF-11, PF-16**	**20 (Extremo)PF-02, PF-03**
03 – MODERADO	03 (Bajo)	**06 (Medio)PF-19**	**09 (Medio)PF-08, PF-14, PF-15**	**12 (Alto)PF-05**	15 (Muy Alto)
02 – POCO PROBABLE	02 (Muy Bajo)	04 (Bajo)	06 (Medio)	**08 (Medio)PF-17, PF-20**	**10 (Alto)PF-10**
01 – RARO	01 (Muy Bajo)	02 (Muy Bajo)	03 (Bajo)	04 (Medio)	05 (Medio)

Soporte (Gestión Documental y Difusión del SGSI)

7.1 Minuta de Reunión: Presentación del SGSI e Identificación de Acuerdos y Áreas de Oportunidad

- **Lugar y Fecha:** Sala de Juntas de la Dirección General de INTERAFAS, San Luis Potosí.
- **Asunto:** Presentación oficial y socialización del Sistema de Gestión de Seguridad de la Información (SGSI - ISO/IEC 27001) enfocado en los procesos de IT y OT.
- **Participantes Presentes (Organigrama Institucional):**
    - Mtra. Valeria Serrano Cruz (Encargada de Despacho - Dirección General).
    - Ing. Bruno Ferrer Lozano (Encargado de Despacho - Tecnologías e Innovación).
    - Ing. Tomás Rivas Calderón (Encargado de Despacho - Operación Hidráulica).
    - Ing. Emilio Navarro Costa (Encargado de Despacho - Monitoreo Operacional).
    - Mtra. Natalia Correa Vidal (Encargada de Despacho - Atención Ciudadana).
    - Equipo Consultor y de Ciberseguridad.

Desarrollo de la Sesión

Se presentó ante la Alta Dirección y directores de área el diagnóstico de vulnerabilidades y la necesidad imperativa de desplegar el SGSI para proteger la infraestructura crítica de telemetría y los portales de atención ciudadana digital. Se detallaron los riesgos críticos encontrados en la matriz (inyecciones SQL, *bypass* de válvulas, falsificación de cabeceras IP y exposición de contraseñas de soporte).

Acuerdos Establecidos

1. **Aprobación del Alcance:** La Alta Dirección aprueba formalmente la implementación inicial del SGSI en los procesos de Atención Ciudadana Digital y en el Centro de Operación Hidráulica (Telemetría e infraestructura SCADA).
2. **Asignación de Recursos:** La Dirección de Administración y Finanzas colaborará en la asignación de recursos para la actualización tecnológica de credenciales y la implementación de controles de doble factor (MFA).
3. **Calendario de Auditorías Internas:** Se acuerda realizar revisiones trimestrales conjuntas entre las áreas de TI y Operación Hidráulica para verificar el cierre de brechas técnicas.

Áreas de Oportunidad Identificadas

- **Capacitación Transversal:** Fomentar una cultura de ciberseguridad obligatoria que rompa la brecha operativa entre el personal administrativo (IT) y el personal técnico de campo (OT).
- **Modernización de Canales:** Aprovechar la transición hacia el Observatorio Hídrico Metropolitano para rediseñar la arquitectura de red bajo el modelo de seguridad en capas (*Defense-in-Depth*).

7.2 Soporte Documental en Materia de Prevención y Concientización

Derivado de las amenazas críticas identificadas en la matriz de riesgos (tales como ataques de inyección, descifrado de credenciales y manipulación de pasarelas), se ha elaborado el siguiente material de soporte preventivo para la mitigación del factor humano y técnico:



Operación (Matriz RACI)

Para garantizar la correcta ejecución, seguimiento y control de las actividades operativas del Sistema de Gestión de Seguridad de la Información (SGSI) en INTERAFAS, se establece la siguiente Matriz de Asignación de Responsabilidades (RACI).

Definición de Roles (Columnas)

- **DG:** Dirección General (Mtra. Valeria Serrano Cruz).
- **TI:** Dirección de Tecnologías e Innovación (Ing. Bruno Ferrer Lozano).
- **OH:** Dirección de Operación Hidráulica / Monitoreo (Ing. Tomás Rivas Calderón / Ing. Emilio Navarro Costa).
- **AC:** Dirección de Atención Ciudadana (Mtra. Natalia Correa Vidal).
- **CS:** Equipo Consultor de Ciberseguridad / Auditoría.

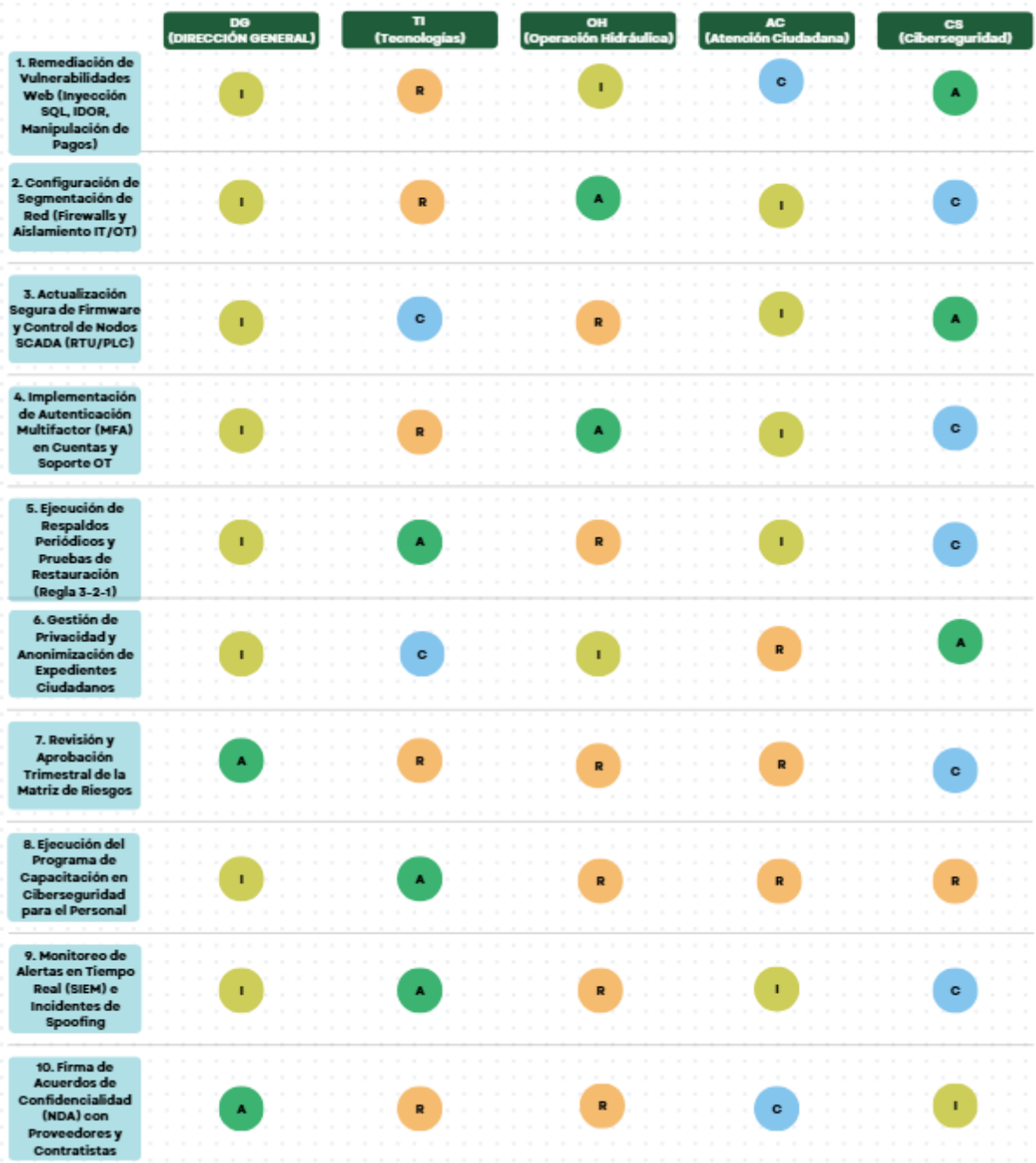
Niveles de Responsabilidad

- **[R] Responsable (*Responsible*):** Quien ejecuta el trabajo o tarea.
- **[A] Aprobador (*Accountable*):** Quien tiene la responsabilidad final sobre la tarea y debe aprobar el trabajo (solo puede haber una "A" por actividad).
- **[C] Consultado (*Consulted*):** Quien aporta información, conocimientos o validación técnica antes de finalizar la tarea.
- **[I] Informado (*Informed*):** Quien debe ser notificado sobre el progreso o los resultados de la tarea.

Actividades Operaticas

- Remediación Web: Mitigación de inyecciones SQL, IDOR y manipulación de pagos.
- Segmentación de Red: Aislamiento perimetral y separación estricta entre las redes IT y OT.
- Control de Firmware: Verificación criptográfica y actualización segura de nodos SCADA (RTU-GW-07).
- Autenticación Avanzada: Implementación de MFA y cifrado robusto para cuentas y soporte técnico.
- Respaldos Periódicos: Automatización, cifrado AES-256 y pruebas de restauración de bases de datos.
- Privacidad de Datos: Protección y tratamiento regulado de los expedientes y datos ciudadanos.
- Revisión de Riesgos: Evaluación trimestral del nivel de riesgo de los 20 activos de información.
- Concientización: Capacitación obligatoria y difusión de materiales preventivos para el personal.
- Monitoreo SIEM: Vigilancia de bitácoras y detección de anomalías como *IP Spoofing*.

- Gestión de Terceros: Firma obligatoria de acuerdos de confidencialidad (NDA) con contratistas.



Evaluacion del Desempeño (Listas de Verificación del SGSI)

Para medir, supervisar y evaluar de forma objetiva el grado de cumplimiento y el funcionamiento de los controles implementados en el Sistema de Gestión de Seguridad de la Información (SGSI), se establecen las siguientes **Listas de Verificación (*Checklists*) de Auditoría Interna**. Estas listas están divididas en los tres procesos clave del alcance: el componente corporativo web (IT), el componente de atención ciudadana y el componente de infraestructura crítica industrial (OT).

9.1 Lista de Verificación 01: Componente Web y Transaccional (IT / Pasarela de Pagos)

Objetivo: Verificar la mitigación de vulnerabilidades web críticas y la correcta protección de las bases de datos ciudadanas.

ID	Criterio de Verificación / Control ISO 27001	Estado (Cumple / No Cumple / En Proceso)	Evidencia Requerida / Método de Validación
CK-01	¿Se eliminaron los archivos residuales (.bak, .old), notas de despliegue y listados de directorios en producción?	**Cumple**	Inspección de directorios raíz y escaneo de rutas web ocultas.
CK-02	¿Se corrigieron las consultas dinámicas vulnerables a Inyección SQL (Blind SQLi) mediante sentencias preparadas?	**Cumple**	Reporte de pruebas estáticas (SAST) y pruebas de penetración web.
CK-03	¿Se implementó una validación estricta de pertenencia de objeto para prevenir accesos no autorizados por IDOR/BOLA?	**Cumple**	Pruebas funcionales de control de acceso por sesión de usuario.
CK-04	¿La pasarela de pagos valida los importes exclusivamente en	**Cumple**	Auditoría de flujo de transacciones y

ID	Criterio de Verificación / Control ISO 27001	Estado (Cumple / No Cumple / En Proceso)	Evidencia Requerida / Método de Validación
	el servidor y opera bajo un proveedor certificado PCI-DSS?		certificado de la pasarela externa.
CK-05	¿Se configuró el WAF (*Web Application Firewall*) y las cabeceras de seguridad HTTP (HttpOnly, Secure, HSTS)?	**Cumple**	Análisis de cabeceras de respuesta HTTP y bitácoras de bloqueo perimetral.

9.2 Lista de Verificación 02: Componente de Infraestructura Crítica y Telemetría (OT / SCADA)

Objetivo: Comprobar el aislamiento de la red industrial y la seguridad en el control de actuadores de campo.

ID	Criterio de Verificación / Control ISO 27001	Estado (Cumple / No Cumple / En Proceso)	Evidencia Requerida / Método de Validación
CK-06	¿Se encuentra la red de control industrial (OT) segmentada y aislada de la red corporativa mediante firewalls?	**Cumple**	Revisión de diagramas topológicos y reglas de filtrado en pasarelas.
CK-07	¿Se eliminó la confianza ciega en la cabecera HTTP X-Forwarded-For para evitar ataques de *IP Spoofing* en el gateway?	**Cumple**	Pruebas de simulación de origen de red y validación de sockets TCP.
CK-08	¿Los manifiestos de actualización de firmware (RTU-GW-07) carecen de	**Cumple**	Inspección de archivos de configuración de despliegue de firmware.

ID	Criterio de Verificación / Control ISO 27001	Estado (Cumple / No Cumple / En Proceso)	Evidencia Requerida / Método de Validación
	hashes públicos débiles y exigen firma criptográfica?		
CK-09	¿Las contraseñas de la Mesa de Soporte OT utilizan algoritmos seguros de derivación (Argon2id/bcrypt) y MFA?	**Cumple**	Revisión de políticas de almacenamiento de credenciales y esquemas de autenticación.
CK-10	¿Se requiere una validación de doble factor o confirmación estricta antes de enviar comandos de apertura/cierre a válvulas (V-SL-201)?	**Cumple**	Pruebas operativas sobre la interfaz HMI del Centro de Operaciones.

9.3 Lista de Verificación 03: Componente de Gobernanza, Procesos y Factor Humano

Objetivo: Validar la correcta documentación, gestión de respaldos y concientización del personal institucional.

ID	Criterio de Verificación / Control ISO 27001	Estado (Cumple / No Cumple / En Proceso)	Evidencia Requerida / Método de Validación
CK-11	¿Se encuentran formalmente definidas y aprobadas por la Alta Dirección las 20 políticas funcionales vinculadas a los activos?	**Cumple**	Manual documental del SGSI con firmas de autorización institucional.
CK-12	¿Se ejecutan respaldos periódicos cifrados (AES-256)	**Cumple**	Bitácoras de ejecución de *backups* y reportes

ID	Criterio de Verificación / Control ISO 27001	Estado (Cumple / No Cumple / En Proceso)	Evidencia Requerida / Método de Validación
	bajo la regla 3-2-1 con pruebas semestrales de restauración?		de pruebas de recuperación.
CK-13	¿Se ha impartido el programa de concientización en ciberseguridad y distribuido el material preventivo al personal?	**Cumple**	Listas de asistencia a talleres y registros de difusión del flyer institucional.
CK-14	¿Se actualiza y revisa trimestralmente la matriz de riesgos para evaluar el tratamiento de los 20 activos de información?	**Cumple**	Actas de revisión de riesgos y minutas de seguimiento con directores de área.
CK-15	¿Se suscriben acuerdos de confidencialidad (NDA) obligatorios con todos los proveedores y contratistas tecnológicos externos?	**Cumple**	Expedientes legales y contratos vigentes en el departamento jurídico.

Mejora

A partir de los resultados obtenidos en el checklist de auditoría interna de la Sección 09, se identificó un incumplimiento operativo en el área de infraestructura crítica, requiriendo acciones correctivas inmediatas según el ciclo de mejora continua del SGSI.

10.1 Hallazgo de Auditoría: Política Funcional que No Logró el Objetivo

Durante la evaluación, el criterio **CK-09** (relacionado con la política **PF-07: Credenciales de la Mesa de Soporte OT**) fue evaluado como "No Cumple".

- **Problema detectado:** La exigencia de contraseñas complejas de 14 caracteres generó fricción operativa en el Centro de Operación Hidráulica. Durante maniobras de emergencia en la interfaz HMI para el control de válvulas, los operadores demoraban en la autenticación o, para evitar bloqueos, anotaban las contraseñas en notas adhesivas físicas adheridas a los monitores, vulnerando la confidencialidad y el control de acceso.

10.2 Mejora de la Política Funcional (PF-07 Rediseñada)

Para corregir la vulnerabilidad sin afectar los tiempos de respuesta ante emergencias hídricas, se rediseña la política funcional **PF-07** eliminando la dependencia de contraseñas memorizables y transitando hacia un modelo de autenticación basada en hardware (Passwordless):

PF-07 Rediseñada: Autenticación por Hardware en la Mesa de Soporte OT

- **Estándar:** ISO/IEC 27001 (Control A.5.17 Información de autenticación y A.8.2 Gestión de acceso privilegiado).
- **Directriz:** El acceso a las terminales críticas de control SCADA e infraestructura HMI queda estrictamente desvinculado de contraseñas alfanuméricas tradicionales. Todo operador debe autenticarse utilizando un token físico de seguridad por hardware (estándar FIDO2/U2F) intransferible.
- **Procedimiento:**
    1. Registrar biométricamente o mediante PIN corto el token de seguridad físico (llave USB/NFC) asignado a cada operador.
    2. Insertar el token en la terminal SCADA y presionar el sensor táctil para autorizar el envío de comandos críticos (ej. apertura de la válvula V-SL-201).
    3. Retirar el token de la terminal al finalizar el turno; el sistema bloqueará la sesión automáticamente tras la extracción física.

- **Línea Base:** Desactivación de autenticación por usuario/contraseña en el *Active Directory* para perfiles OT. Uso exclusivo de llaves físicas con cifrado asimétrico y certificados por hardware.

10.3 Rediseño del Soporte de Prevención (Flyer Actualizado)

Dado que la política cambió, el material de concientización original centrado en "contraseñas robustas" quedó obsoleto y se rediseña para capacitar al personal en el nuevo esquema tecnológico.



Conclusión

La implementación del Sistema de Gestión de Seguridad de la Información (SGSI) bajo el estándar ISO/IEC 27001 representa un paso estratégico definitivo para INTERAFAS en su proceso de digitalización y modernización. Al estructurar el alcance sobre las áreas de Tecnologías e Innovación (IT) y Operación Hidráulica (OT), el proyecto logra integrar la protección de los datos ciudadanos en el portal web con el aseguramiento físico y lógico de la infraestructura SCADA y de telemetría. La ejecución metodológica a lo largo del documento, desde el inventario de activos hasta el rediseño de políticas preventivas —como la transición hacia la autenticación mediante tokens de hardware en entornos operativos—, demuestra un enfoque adaptable y orientado a la mejora continua. Este marco normativo permite al organismo intermunicipal no solo mitigar vulnerabilidades críticas operativas y cumplir con las regulaciones vigentes, sino materializar directamente su visión institucional de mantener una red hídrica metropolitana resiliente, medible y capaz de garantizar la continuidad ininterrumpida del servicio frente a escenarios de riesgo cibernético.